

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Кампания сбора учётных данных на взломанных сайтах WordPress — приманки под бренд и под собственный домен

Credential Phishing • Brand Spoofing • Compromised WordPress • Redirect Abuse • PhaaS

Параметр	Значение
Период	6–7 июля 2026 (две волны)
Классификация	Фишинг для кражи учётных данных (credential harvesting)
Уровень угрозы	СРЕДНИЙ
Атрибуция	Общий фишинг-набор / PhaaS, низкая уверенность (разная инфраструктура отправки по волнам)
Цель	Корпоративные почтовые ящики отслеживаемого домена (реквизиты цели скрыты)
Статус	Проанализировано; полезные страницы на скомпрометированных сайтах

1. Краткое заключение

6 и 7 июля 2026 года на корпоративные почтовые ящики отслеживаемого домена поступили два фишинговых письма, объединённых общим набором тактик и, вероятно, единым фишинг-набором (phishing kit / PhaaS). Обе волны нацелены на кражу учётных данных корпоративной почты: жертву склоняют перейти по ссылке и ввести логин/пароль на поддельной странице.

Ключевая особенность кампании — страницы сбора учётных данных размещены не на доменах атакующего, а на взломанных легитимных сайтах под управлением WordPress (пути вида `/wp-includes/...`). Прямая ссылка на фишинг маскируется через цепочку редиректов (сокращатель `t.co`, открытый редирект `google.com/url`). Отправка обеих волн выполнена со спуфингом отправителя и провалом SPF (softfail).

Волны отправлены с разной инфраструктуры (резидентский адрес в Болгарии и хостинг-адрес в Нидерландах), но имеют идентичную схему исполнения. Это указывает на использование общего фишинг-набора несколькими операторами, а не на одну целенаправленную операцию. Отчёт публикуется для того, чтобы защитники могли заблокировать конкретные вредоносные URL и уведомить владельцев скомпрометированных сайтов.

2. Обзор кампании

Наблюдались две волны с интервалом в сутки. Обе имитируют легитимное уведомление и содержат минимум текста, чтобы быстро увести пользователя на внешнюю страницу ввода учётных данных.

Признак	Волна 1 (6 июля)	Волна 2 (7 июля)
Приманка (бренд)	American Express KYC	Администратор собственного домена жертвы
Тема письма	«Reminder: Your action is needed»	«Unrecognized Login / [9] pending incoming Emails»
Отправитель (IP)	78[.]130[.]245[.]134	77[.]83[.]39[.]10
Тип сети	Резидентский ISP (Болгария)	ЦОД / хостинг (Нидерланды)
Аутентификация	SPF softfail (спуф)	SPF softfail (спуф)
Обфускация ссылки	Сокращатель t.co	Открытый редирект google.com/url
Страница сбора	взломанный WordPress	взломанный WordPress + скомпрометированный сайт

3. Волна 1 — имперсонация бренда American Express (6 июля)

Письмо имитирует уведомление службы верификации American Express («KYC») с темой «Reminder: Your action is needed». Отправлено с адреса 78[.]130[.]245[.]134 — резидентского подключения болгарского провайдера (репутация AbuseIPDB 47, множественные жалобы). Отправитель подделан под бесплатный почтовый сервис; проверка SPF завершилась softfail, то есть адрес не авторизован для отправки от имени заявленного домена.

Тело письма насыщено легитимными ссылками на americanexpress.com (декои), среди которых спрятана единственная действующая ссылка — короткий адрес сокращателя t.co. Он ведёт (через редирект) на страницу сбора учётных данных, размещённую на взломанном сайте под управлением WordPress: hxxps://taylorfoothealth[.]co[.]uk/wp-includes/paymm[.]html. Сам сайт (клиника в Великобритании) является добросовестной жертвой компрометации.

4. Волна 2 — спуфинг собственного домена (7 июля)

Вторая волна имитирует служебное уведомление «администратора» собственного домена получателя: тема «Unrecognized Login» / «[9] pending incoming Emails», призыв «Action Required». Отправлено с адреса 77[.]83[.]39[.]10 — адреса дата-центра в Нидерландах (репутация AbuseIPDB 100, 393 жалобы; заведомо вредоносный узел рассылки). Проверка SPF также завершилась softfail.

В письме — две ссылки на страницы сбора учётных данных, обе на взломанных легитимных сайтах: hxxps://habitatcyprus[.]com/wp-includes/build/ (взломанный WordPress) и — через открытый редирект google.com/url?q= — hxxps://lavilifescience[.]com/authn/mail/login[.]html. Вторая страница подставляет адрес жертвы через шаблонный токен, чтобы придать форме входа правдоподобие.

4.1. Извлечённая нагрузка и механика набора

Страница сбора учётных данных была извлечена (анонимно) и проанализирована. Это статический harvester под «Webmail» (не AiTM/reverse-proxy). HTML страницы обфусцирован приёмом document.write(unescape('%XX...')). Форма содержит поле email (только для чтения, предзаполнено адресом жертвы), поле password и скрытое honeypot-поле _gotcha.

Кража выполняется на стороне клиента: JavaScript отправляет введённые данные методом fetch POST (JSON) на легитимный сервис форм Formspark — hxxps://submit-form[.]com/4FJePSjAq.

Реализован «двойной сбор» (метка attempt=first/second): при первой отправке имитируется ошибка, чтобы жертва ввела пароль повторно и был отсеян опечаточный ввод. После кражи пользователь перенаправляется на hxxps://<домен-из-его-email>, чтобы визит выглядел завершённым штатно. Файлы набора обслуживаются небольшим PHP-фреймворком (routes.php, pages.php, registry.php), который оказался доступен через открытый листинг директории.

Оценка сложности — низкая (коммодити-набор, злоупотребление публичным SaaS для эксфильтрации вместо собственной инфраструктуры). Канал слива Formspark (form ID 4FJePSjAq) — приоритетная цель для take-down: его отключение обрывает получение украденных учётных данных.

5. Оценка и общие тактики

Несмотря на разные бренды-приманки и разную инфраструктуру отправки, обе волны исполнены по одной схеме, что указывает на общий фишинг-набор:

- Спуфинг отправителя (бренд или собственный домен жертвы) с провалом SPF (softfail).
- Страницы сбора учётных данных размещены на взломанных легитимных сайтах WordPress (пути /wp-includes/...), а не на доменах атакующего — это осложняет блокировку по домену и продлевает жизнь инфраструктуры.
- Обфускация полезной ссылки через доверенные редиректы (t.co, google.com/url), чтобы обойти репутационную фильтрацию.
- Разные отправляющие узлы по волнам (резидентский BG, ЦОД NL) — признак нескольких операторов одного набора (PhaaS), а не единой целевой операции.

Важно: домены таких страниц (taylorfoothealth[.]co[.]uk, habitatcyprus[.]com, lavilifescience[.]com) принадлежат добросовестным организациям и сами являются жертвами компрометации.

Защитникам следует блокировать конкретные вредоносные URL, а не домены целиком, и по возможности уведомить владельцев сайтов.

6. Индикаторы компрометации (IOC)

Значения указаны в обезвреженном (defanged) виде. Продакшн-версии — в машиночитаемых дампах STIX 2.1 / MISP.

Тип	Значение	Контекст
IP (src)	78[.]130[.]245[.]134	Сооолбох AD, Болгария, резидентский; AbuseIPDB 47. Отправитель волны 1.
IP (src)	77[.]83[.]39[.]10	Lanedonet/Pitline Ltd, Нидерланды, ЦОД; AbuseIPDB 100. Отправитель волны 2.
URL	hxxps://taylorfoothealth[.]co[.]uk/wp-includes/paymm[.]html	Страница сбора учётных данных (взломанный WordPress).
URL	hxxps://habitatcyprus[.]com/wp-includes/build/	Страница сбора учётных данных (взломанный WordPress).
URL	hxxps://lavilifescience[.]com/authn/mail/login[.]html	Страница сбора учётных данных (скомпрометированный сайт).
URL (эксфил)	hxxps://submit-form[.]com/4FJePSjAq	Formspark: конечная точка слива украденных учётных данных (kit POST-ит сюда JSON). Цель для take-down.
Редирект	hxxps://t[.]co/W8S9YV2vYD	Обфускация ссылки (сокращатель); не блокировать t.co целиком.
Редирект	google[.]com/url?q=	Открытый редирект для маскировки полезной ссылки.

6.1. MITRE ATT&CK

- T1566.002 — Phishing: Spearphishing Link
- T1656 — Impersonation
- T1584.004 — Compromise Infrastructure: Server

7. Рекомендации

- Заблокировать перечисленные вредоносные URL и отправляющие IP на почтовом шлюзе и прокси.
- Блокировать конкретные URL, а не домены скомпрометированных сайтов; уведомить владельцев сайтов о компрометации (пути /wp-includes/...).
- Усилить проверку выравнивания SPF/DKIM/DMARC; пометать письма от собственного домена, пришедшие извне и не прошедшие аутентификацию.
- Обучать пользователей распознавать приманки «unrecognized login» / «pending emails» и не вводить учётные данные по ссылкам из писем; включить FIDO2/MFA, устойчивый к фишингу.
- Отслеживать редиректы через доверенные сервисы (t.co, google.com/url) как возможный обход репутационных фильтров.

TLP:CLEAR — Этот документ может распространяться без ограничений.